

Agent Guardrails Checklist

Five decisions to make before any AI agent touches a real system: your client portal, shared drive, inbox, or CRM. One sheet per agent. Built for firms that handle client data without a full IT or compliance team.

Agent / tool: _____

Owner: _____

Go-live date: _____

01 Scope it Access questions to answer before go-live

- ☐ List every system, account, and folder this agent can reach. Everything not on the list is off-limits by default.
- ☐ It has its own login, not a staff member's shared credentials.
- ☐ Access is read-only anywhere it does not need to write, send, or delete.
- ☐ Client data it can see is limited to what the task needs, nothing broader.
- ☐ **The leak test:** if this agent's login leaked tomorrow, what could someone reach with it? If the answer makes you wince, the scope is too wide.

02 Give it a stop rule Hard-code this, word for word

"If you are blocked, denied access, or need a login you don't have: stop. Report what you tried. Do not look for another way in."

- ☐ The rule is in the agent's instructions or system prompt, not just in someone's head.
- ☐ It must also stop and ask before it: deletes anything, sends anything outside the firm, moves money, or changes permissions.
- ☐ Someone tested it once: blocked the agent on purpose and confirmed it stopped.

03 Log everything What to log, and who reviews it

- ☐ Every action, file touched, and login attempt is logged, with a timestamp.
- ☐ Logs are stored where the agent itself cannot edit or delete them.
- ☐ Alerts go to a human for: access denied, failed logins, and activity outside business hours.
- ☐ Reviewer: _____ Review day: _____ (15 minutes, weekly, on the calendar)

04 Pre-write your disclosure plan Fill in the blanks now, not during an incident

If this agent touches something it shouldn't, we'd know within _____ hours because _____

The person who pauses the agent: _____ Backup: _____

First call (name and phone): _____

Clients we would tell: _____ within _____ hours, by _____

Also notify (insurer, regulator, IT vendor): _____

Check your notification duties with your cyber insurer or counsel. This sheet is a planning aid, not legal advice.

05 Name an owner If nobody owns it, nobody stops it

- ☐ One accountable human for this agent: _____
- ☐ The owner can pause or shut it off without asking anyone.
- ☐ Next review of this sheet: _____ (at least every 90 days, and after any change in access)